Romney, M.B et.all (2021). Accounting Information Systems 15th: Chapters 8, 11, 12, 13

AIS

Kiểm soát hệ thống thông tin kế toán

Accounting Information Systems Controls

Nguyễn Bích Liên

Mục tiêu

1. Hiểu các thủ tục kiểm soát cần thiết để đảm bảo an toàn cho thông tin
2. Hiểu các thủ tục kiểm soát cần thiết để đảm bảo bảo mật thông tin nhạy cảm của DN
3. Bảo vệ tính riêng tư thông tin cá nhân của các bên có lợi ích liên quan
4. Hiểu các thủ tục kiểm soát cần thiết để đảm bảo tính toàn vẹn của thông tin
5. Các thủ tục kiểm soát cần thiết để đảm bảo tính sẵn sàng, liên tục của hệ thống

Nội dung

1. Kiểm soát an toàn thông tin
2. Kiểm soát bảo mật thông tin
3. Kiểm soát quyền riêng tư
4. Kiểm soát tính toàn vẹn
5. Kiểm soát tính khả dụng của hệ thống

Thuật ngữ

STT	Thuật ngữ	Trang	Diễn giải
1	Access control matrix	237	Ma trận kiểm soát truy cập
2	Authentication	235	Xác thực
3	Backup	294	Sao lưu
4	Batch totals	289	Tổng lô
5	Business continuity plan	297	Kế hoạch tiếp tục kinh doanh
6	Change control and change management	246	Kiểm soát thay đổi và quản lý việc thay đổi
7	Check digit	288	Số kiểm tra
8	Check digit verification	288	Xác nhận số kiểm tra
9	Checksum	291	Kỹ thuật kiểm tra độ chính xác của dữ liệu truyền tải thông qua thuật toán băm của tập tin
10	Closed-loop verification	289	Kiểm tra vòng lặp kín

Thuật ngữ

	Thuật ngữ	Trang	Diễn giải
11	Compatibility test	237	Kiểm tra sự tương thích giữa các kiểm soát xác nhận và ma trận kiểm soát truy cập
12	Completeness check (or test)	288	Kiểm tra tính đầy đủ
13	Concurrent update controls	290	Kiểm tra cập nhật đồng thời
14	Cookies	267	Cookies
15	Cross-footing balance test		Kiểm tra chéo số dư
16	Data loss prevention (DLP)	263	Phần mềm ngăn ngừa việc mất dữ liệu
17	Data masking	265	Chương trình làm thay đổi giá trị thực của dữ liệu
18	Defense-in-depth	231	Nguyên tắc an toàn phòng thủ sâu
19	Differential backup	296	Sao lưu lũy tiến
20	Digital watermark	263	Mã đánh dấu

Thuật ngữ

	Thuật ngữ	Trang	Diễn giải
21	Disaster recovery plan (DRP)	296	Kế hoạch phục hồi sau thảm họa
22	Encryption	269	Mã hóa
23	Fault tolerance	293	Dung sai/ sức chịu đựng lỗi hệ thống
24	Field check	288	Kiểm tra kiểu dữ liệu
25	Financial total	289	Tổng tài chính
26	Hash total	289	Tổng hash
27	Incremental backup	295	Sao lưu từng phần
28	Information rights management (IRM)	262	Phần mềm quản trị quyền thông tin
29	Intrusion detection system (IDS)	248	Hệ thống phát hiện thâm nhập
30	Limit check	288	Kiểm tra giới hạn

Thuật ngữ

STT	Thuật ngữ	Trang	Diễn giải
31	Log analysis	247	Phân tích nhật ký
32	Multifactor authentication	235	
33	Multimodal authentication	235	
34	Parity bit	291	Một bit được thêm vào dữ liệu truyền tải nhằm kiểm tra sự chính xác
35	Parity checking	291	Kiểm soát sự chính xác thông tin qua kỹ thuật parity
36	Penetration test	248	Kiểm tra sự xâm nhập/kiểm tra bảo mật
37	Prompting	289	Nhắc nhập liệu
38	Range check	288	Kiểm tra giới hạn
39	Reasonableness test	288	Kiểm tra hợp lý
40	Record count	289	Đếm mẫu tin

Thuật ngữ

STT	Thuật ngữ	Trang	Diễn giải
41	Recovery point objective	295	Mốc phục hồi dữ liệu
42	Recovery time objective	295	Mốc thời gian phục hồi
43	Sequence check	289	Kiểm tra tuần tự
44	Sign check	288	Kiểm tra dấu
45	Size check	288	Kiểm tra dung lượng
46	Time-based model of security	231	Nguyên tắc an toàn dựa trên thời gian
47	Turnaround document	288	Chứng từ luân chuyển
48	Validity check	288	Kiểm tra hợp lệ
49	Zero-balance test	290	Kiểm tra số dư bằng 0

Giới thiệu các nguy cơ với AIS

TABLE 8-1 Threats to Accounting Information Systems

Threats	Examples
Natural and political disasters	Fire or excessive heat
	Floods, earthquakes, landslides, hurricanes, tornadoes, blizzards, snowstorms, and freezing rain
	War and attacks by terrorists
Software errors and equipment malfunctions	Hardware or software failure
	Software errors or bugs
	Operating system crashes
	Power outages and fluctuations
	Undetected data transmission errors
Unintentional acts	Accidents caused by human carelessness, failure to follow established procedures, and poorly trained or supervised personnel
	Innocent errors or omissions
	Lost, erroneous, destroyed, or misplaced data
	Logic errors
	Systems that do not meet company needs or cannot handle intended tasks
Intentional acts	Sabotage
	Misrepresentation, false use, or unauthorized disclosure of data
	Misappropriation of assets
	Financial statement fraud
	Corruption
	Computer fraud—attacks, social engineering, malware, etc.

Giới thiệu các nguy cơ với AIS

- Thảm họa thiên tai và chính trị
- Các sai sót phần mềm và sử dụng thiết bị
- Các sơ sót
- Các gian lận

Giới thiệu các nguy cơ với AIS

❖Gian lận máy tính

- **Gian lận đầu vào (input)**: Làm sai lệch thông tin đầu vào của máy tính
- **Gian lận sử dụng thiết bị xử lý** : bao gồm việc sử dụng hệ thống trái phép (trộm cắp thời gian và dịch vụ của máy tính)
- **Gian lận phần mềm**: giả mạo phần mềm của công ty, sao chép phần mềm bất hợp pháp, sử dụng phần mềm trái phép và phát triển phần mềm để thực hiện hoạt động trái phép. Gian lận này đòi hỏi kiến thức lập trình chuyên biệt.

Giới thiệu các nguy cơ với AIS

❖Gian lận máy tính

- **Gian lận dữ liệu**. Sử dụng, sao chép, tìm kiếm hoặc làm hư hại dữ liệu của đơn vị. Nguyên nhân lớn nhất của vi phạm dữ liệu là sơ suất của nhân viên
- **Gian lận đầu ra**
  - Có thể có các thiết bị nhận diện được các tín hiệu phát ra từ các thiết bị hiển thị đầu ra
  - Dùng máy tính làm giả kết quả đầu ra giống như thật. (VD scan 1 SEC, sử dụng thiết bị nhận diện tín hiệu màn hình để xử lý SEC, sửa tên người nhận, số tiền và in SEC giả mạo này)

Kiểm soát hệ thống thông tin

Mục tiêu kiểm soát

Đảm bảo hệ thống thông tin tin cậy

The Trust Services Framework

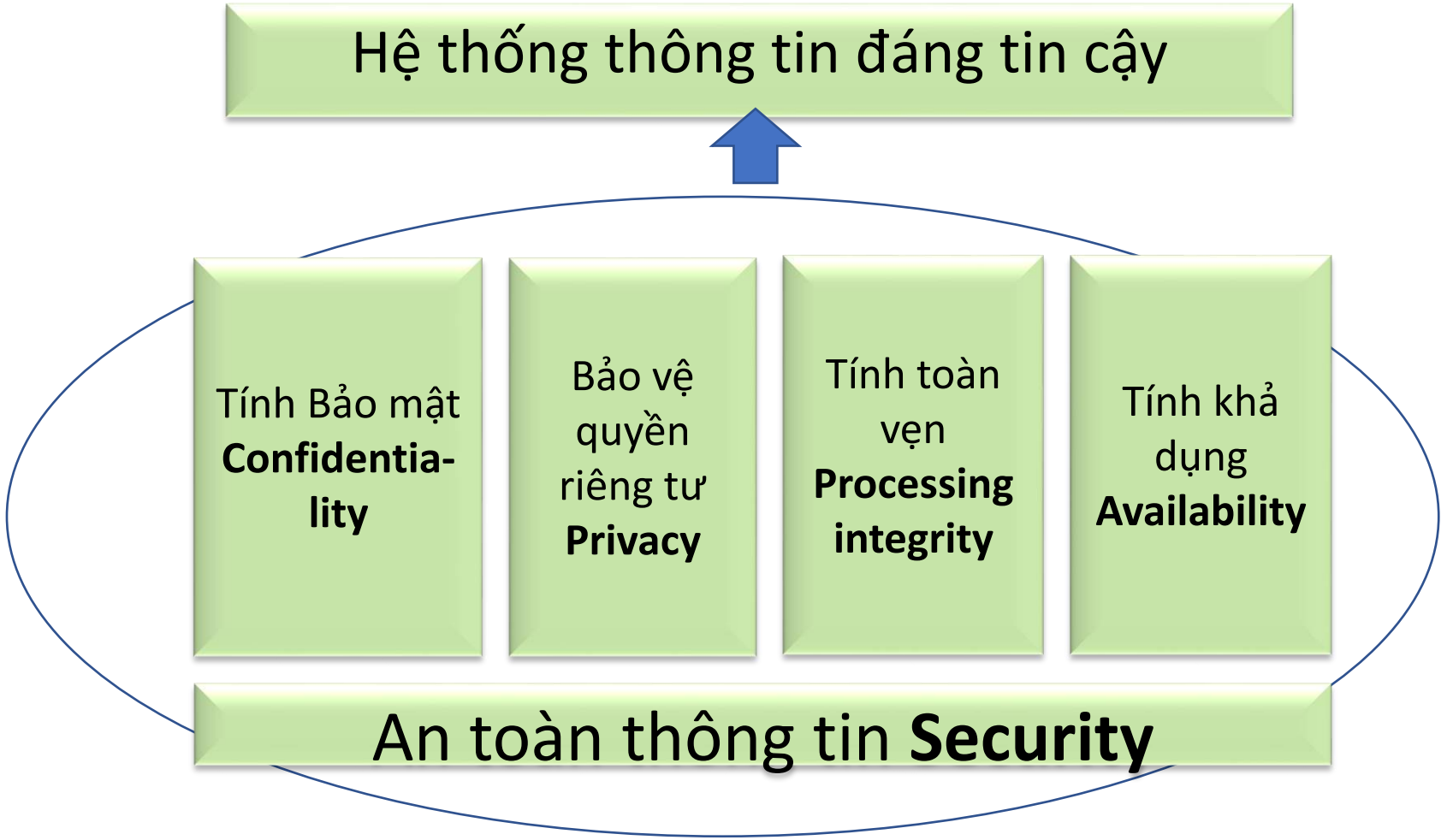
AICPA (the American Institute of Certified Public Accountants)
&
CICA (the Canadian Institute of Chartered Accountants)

Hướng dẫn kiểm toán viên:

- Đánh giá độ tin cậy của hệ thống thông tin một tổ chức
- Thực hiện các dịch vụ chứng thực liên quan đến an ninh mạng.

Kiểm soát hệ thống thông tin

Khuôn mẫu về niềm tin dịch vụ - the Trust services framework



UEH UNIVERSITY

Mục lục

1.1. Ba khái niệm cơ bản ANTT (Three fundamental information security concept)

1.2. Bảo vệ nguồn lực thông tin

1.3. Phát hiện tấn công (Detecting Attacks)

1.4. Đáp trả tấn công (response the attack)

1.5. Giám sát và sửa đổi các giải pháp bảo mật

1.1. Ba khái niệm cơ bản ANTT

❖An toàn là vấn đề quản lý, không phải chỉ là vấn đề kỹ thuật

An toàn (Secure): **Kiểm soát truy cập** (cả vật lý và logic) **vào hệ thống và dữ liệu** của hệ thống

- Ngoài các công cụ kỹ thuật thì cần vai trò các nhóm chức năng trong chu trình ANTT
  - ***BQL cấp cao*** *(Senior management)* tham gia và hỗ trợ toàn bộ chu trình ANTT, đảm bảo cho sự thành công với ANTT
  - ***Nhóm công nghệ thông tin*** *(The information technology function)*: Cài đặt và duy trì giải pháp công nghệ
  - ***Nhóm rủi ro và tuân thủ*** *(The risk and compliance group)*. Thiết kế chính sách ANTT và đảm bảo tuân thủ
  - ***Kiểm toán nội bộ (internal audit)***: Định kỳ thực hiện đánh giá độc lập sự hữu hiêu và hiệu quả của chương trình ANTT

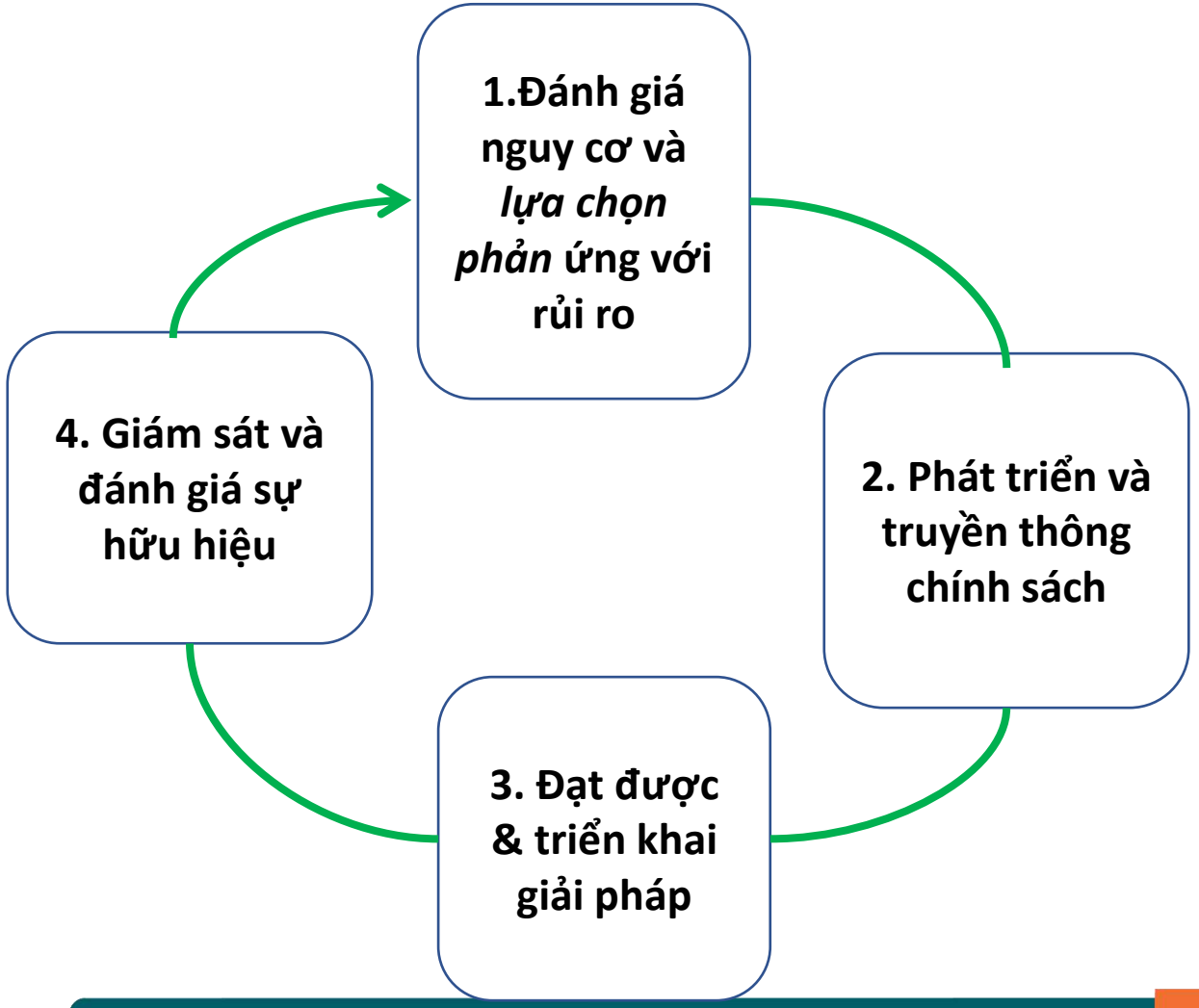
1.1. Ba khái niệm cơ bản ANTT

❖An toàn là vấn đề quản lý, không phải chỉ là vấn đề kỹ thuật

➢ **Chu kỳ An toàn thông tin (Secure life cycle)**

Bước 1.

- Đánh giá nguy cơ: Nhân viên an toàn thông tin
- BQL cấp cao: lựa chọn phản ứng RR



1.1. Ba khái niệm cơ bản ANTT

❖An toàn là vấn đề quản lý, không phải chỉ là vấn đề kỹ thuật

➢ Chu kỳ An toàn thông tin (Secure life cycle)

Bước 2

- *Phát triển chính sách an toàn thông tin (ANTT) :*
  - Quản lý cấp cao tham gia
  - Nhóm rủi ro và tuân thủ chịu trách nhiệm chính
- *Truyền thông chính sách ANTT*:
  - BQL cấp cao hỗ trợ
  - Nhóm rủi ro và tuân thủ chịu trách nhiệm chính



1.1. Ba khái niệm cơ bản ANTT

❖An toàn là vấn đề quản lý, không phải chỉ là vấn đề kỹ thuật

➢ **Chu kỳ An toàn thông tin (Secure life cycle)**

Bước 3

- *Quản lý cấp cao* phải cho phép đầu tư các nguồn lực cần thiết và hỗ trợ quá trình triển khai
- *Nhóm công nghệ TT* và *nhóm rủi ro &tuân thủ* chịu trách nhiệm triển khai



1.1. Ba khái niệm cơ bản ANTT

❖An toàn là vấn đề quản lý, không phải chỉ là vấn đề kỹ thuật

➢ **Chu kỳ An toàn thông tin (Secure life cycle)**

Bước 4

- *Quản lý cấp cao* (1) Xác định lại khẩu vị rủi ro; (2) có thể thực hiện thay đổi chính sách an toàn; (3) xem xét các giải pháp mới
- *Kiểm toán nội bộ:* Đánh giá độc lập sự hữu hiệu và hiệu quả chương trình ANTT



❖ Con người là nhân tố quan trọng

- Con người là tài sản quan trọng và cũng có thể là mắt xích yếu nhất trong ANTT
- Để con người trở thành yếu tố tích cực trong ANTT
  - Tạo văn hóa nhận thức an toàn:
    - ✓Nhân viên tuân thủ chính sách an toàn
    - ✓BQL truyền thông và là tấm gương tuân thủ chính sách an toàn ;
  - Huấn luyện liên tục nhận thức ANTT
    - ✓Hiểu chính sách ANTT
    - ✓Hiểu Các kiểu tấn công giả mạo, đánh lừa người sử dụng
    - ✓Tầm quan trọng của đo lường an toàn thông tin
    - ✓Tuân thủ các thực hành an toàn máy tính

Chương trình huấn luyện sẽ hiệu quả chỉ khi nếu BQL cấp cao luôn hỗ trợ

❖ Mô hình an toàn thông tin dựa trên thời gian (the time-based model of information security)

Mô hình an toàn dựa trên thời gian (Time-base model of security)

P > D + R

Thời gian để **vượt qua các kiểm soát bảo vệ** của DN

Thời gian để **phát hiện** một cuộc tấn công

Thời gian để **phản ứng lại** với cuộc tấn công và thực hiện kiểm soát sửa sai

Gồm kết hợp:

- Kiểm soát ngăn ngừa
- Kiểm soát phát hiện
- Kiểm soát sửa chữa

Xem bảng 11-1, P 366

❖ Mô hình an toàn thông tin dựa trên thời gian (the time-based model of information security)

➢ **Chiến lược Phòng thủ sâu (defense in depth):** Đáp ứng mục tiêu mô hình ANTT dựa trên thời gian

- Triển khai nhiều tầng (multiple layers) kiểm soát để tránh việc có duy nhất một điểm yếu (vd: tường lửa, mật khẩu, mã bảo mật, và bảo mật sinh trắc học).
- Sử dụng kết hợp kiểm soát ngăn ngừa, kiểm soát phát hiện, và kiểm soát sửa chữa.

1.1. Ba khái niệm cơ bản ANTT

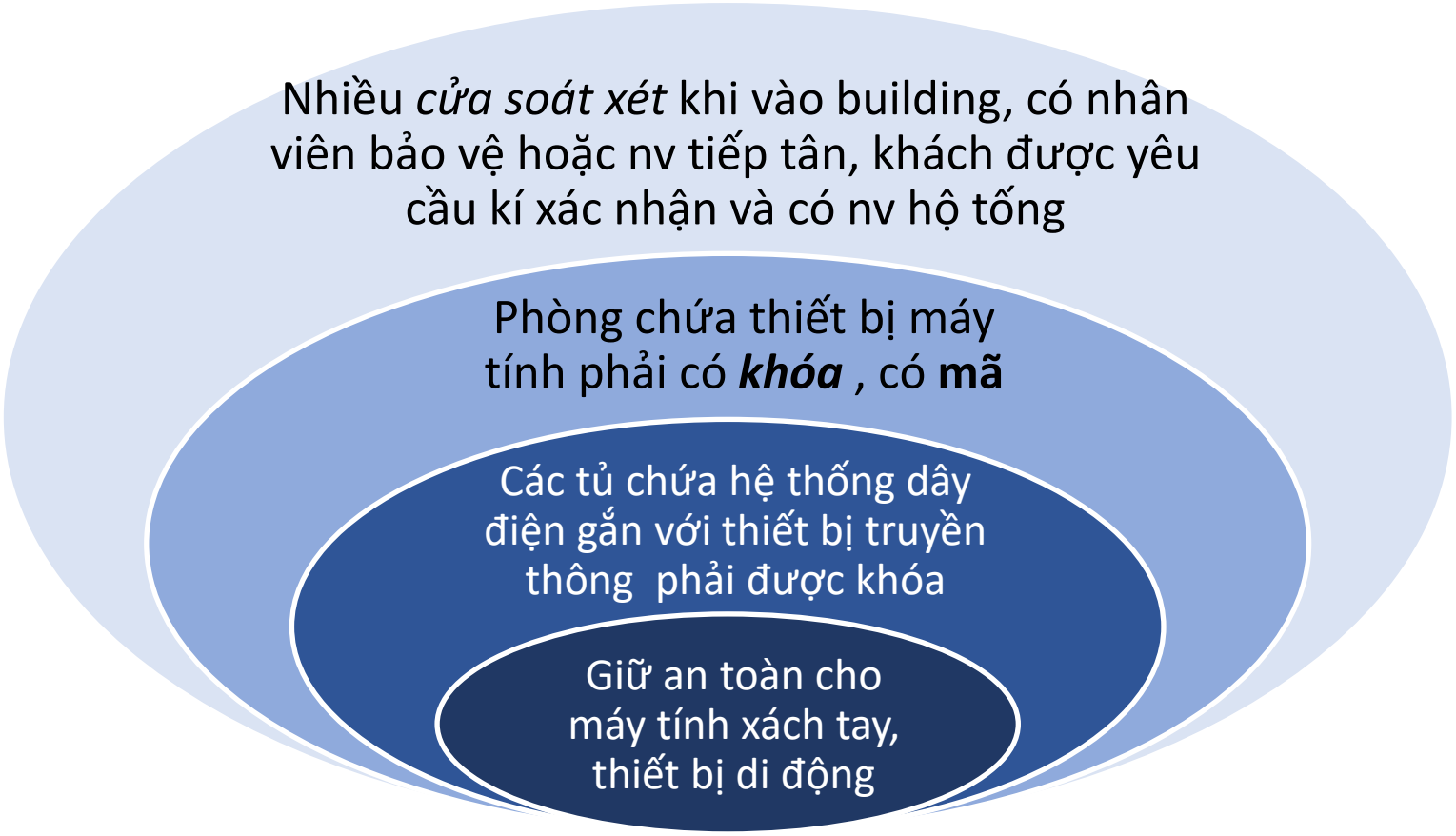
UEH UNIVERSITY

- Mô hình an toàn thông tin dựa trên thời gian (the time-based model of information security)

TABLE 11-1 Preventive, Detective, and Corrective Controls Used to Satisfy the Time-Based Model of Security

Time-Based Model Component	Examples
Protection	• Physical security: access controls (locks, guards, etc.) • Process: User access controls (authentication and authorization) • IT solutions ○ Anti-malware ○ Network access controls (firewalls, intrusion prevention systems, etc.) ○ Device and software hardening (configuration controls) ○ Encryption
Detection	• Log analysis • Intrusion detection systems • Honeypots • Continuous monitoring
Response	• Computer incident response teams (CIRT) • Chief information security officer (CISO)

❖An toàn vật lý: Kiểm soát truy cập vật lý

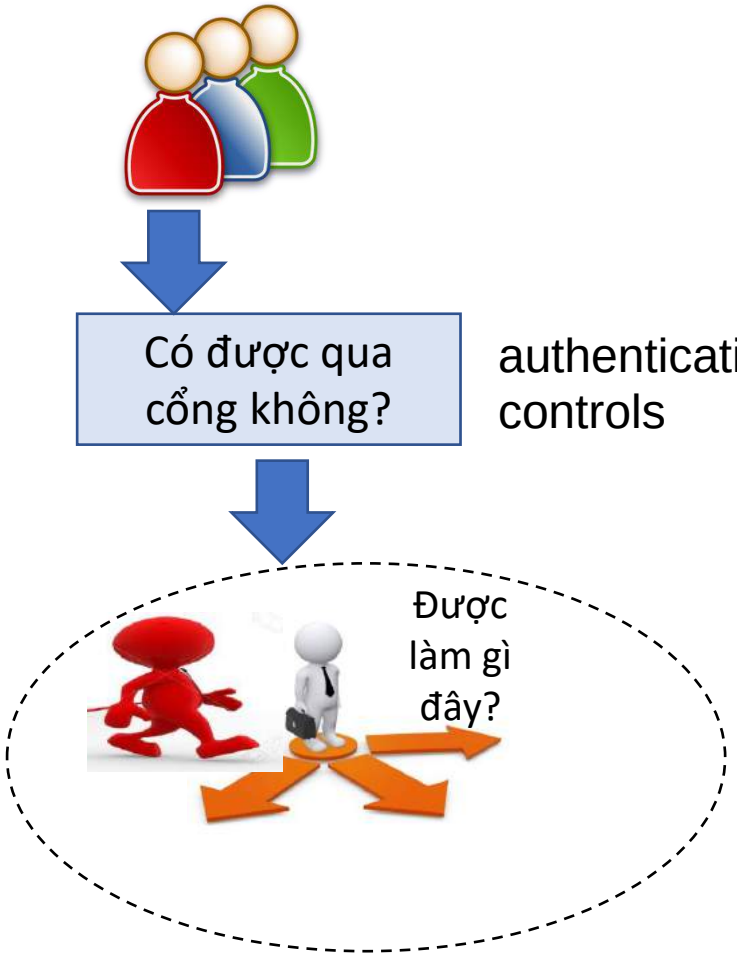


❖An toàn vật lý: Kiểm soát truy cập vật lý

Trường hợp máy tính xách tay, thiết bị di động (đtdd; thiết bị khác)

- Thông tin quan trọng cần mã hóa
- Khóa vật lý thiết bị với 1 vật thể cố định, chắc chắn
- Cài đặt phần mềm nhận diện vị trí của thiết bị truy cập tới mạng doanh nghiệp -> Có thể ra lệnh xóa thông tin nếu bị đánh cắp
- Thực hiện kết hợp kiển soát truy cập từ xa (VD sinh trắc học, thẻ nhận diện..) và kiểm soát truy cập vật lý
- Kiểm soát kết nối qua mạng với máy in (phòng trường hợp thông tin còn lưu trên ổ cứng của máy in)

❖Qui trình : Kiểm soát truy cập người dùng



System access permission:

(1) Physical system access;
(2) Logical system access

Áp dụng cho 4 lớp an toàn:

(1) Mạng (network);
(2) Hệ thống hoạt động Platform (operating system);
(3) Database;
(4) (4) Application

❖Qui trình : Kiểm soát truy cập người dùng

➢ Kiểm soát xác thực (authentication controls)

- Xác thực là quá trình xác minh danh tính của cá nhân hoặc thiết bị đang cố truy cập vào hệ thống, nhằm đảm bảo **chỉ** những **người dùng hợp pháp** mới có thể truy cập vào hệ thống
- 3 cách để xác minh danh tính cá nhân, vdu:
  - Sử dụng mật khẩu, mã PIN
  - Sử dụng thẻ thông minh hoặc phù hiệu cá nhân
  - Sử dụng định danh sinh trắc học

❖Qui trình : Kiểm soát truy cập người dùng

➢ Kiểm soát xác thực (authentication controls)

- ✓ **Xác thực đa yếu tố (**multifactor authentication)**-** sử dụng hai hay nhiều loại thông tin xác thực trong một kết hợp để đạt được mức độ an toàn hơn (Vd kết hợp password và sinh trắc học v..v)

- ✓ **Xác thực đa phương thức (**multimodal authentication)**-**Việc sử dụng nhiều mức độ của cùng loại thông tin xác thực để đạt được mức độ bảo mật cao hơn. Vd: sử dụng đa phương thức sinh trắc học như vân tay, khuôn mặt hoặc mống mắt,

❖Qui trình : Kiểm soát truy cập người dùng

➢ Kiểm soát phân quyền (authorization controls)

- Phân quyền là quá trình hạn chế quyền truy cập của người dùng được xác thực đối với các phần hành cụ thể của hệ thống và hạn chế những thao tác mà họ được phép thực hiện

❑ Cách thực hiện:

- Tạo ma trận kiểm soát truy cập (access control matrix)
- Kiểm tra tương thích (compatibility test) (tương thích giữa người được xác thực và nhiệm vụ được qui định trên ma trận truy cập)

❖Qui trình : Kiểm soát truy cập người dùng

➢ Kiểm soát phân quyền (authoriztion controls)

User	Files			Programs			
User ID	A	B	C	1	2	3	4
NHale	0	0	1	0	0	0	0
JPJones	0	2	0	0	0	0	1
BArnold	1	1	0	1	1	0	0
....	....	....	....	....	....	....	....

Codes for File Access:
0 = No Access
1 = Read/display only
2 = Read/display and update
3 = Read/display, update, create, and delete

Codes for Program Access:
0 = No Access
1 = Execute

FIGURE 8-4
Example of an Access Control Matrix

Câu hỏi: vai trò của người quản lý BP sử dụng và quản lý an toàn (security administration) thế nào trong việc phân quyền và kiểm soát phân quyền ?

❖Qui trình : Kiểm soát truy cập người dùng

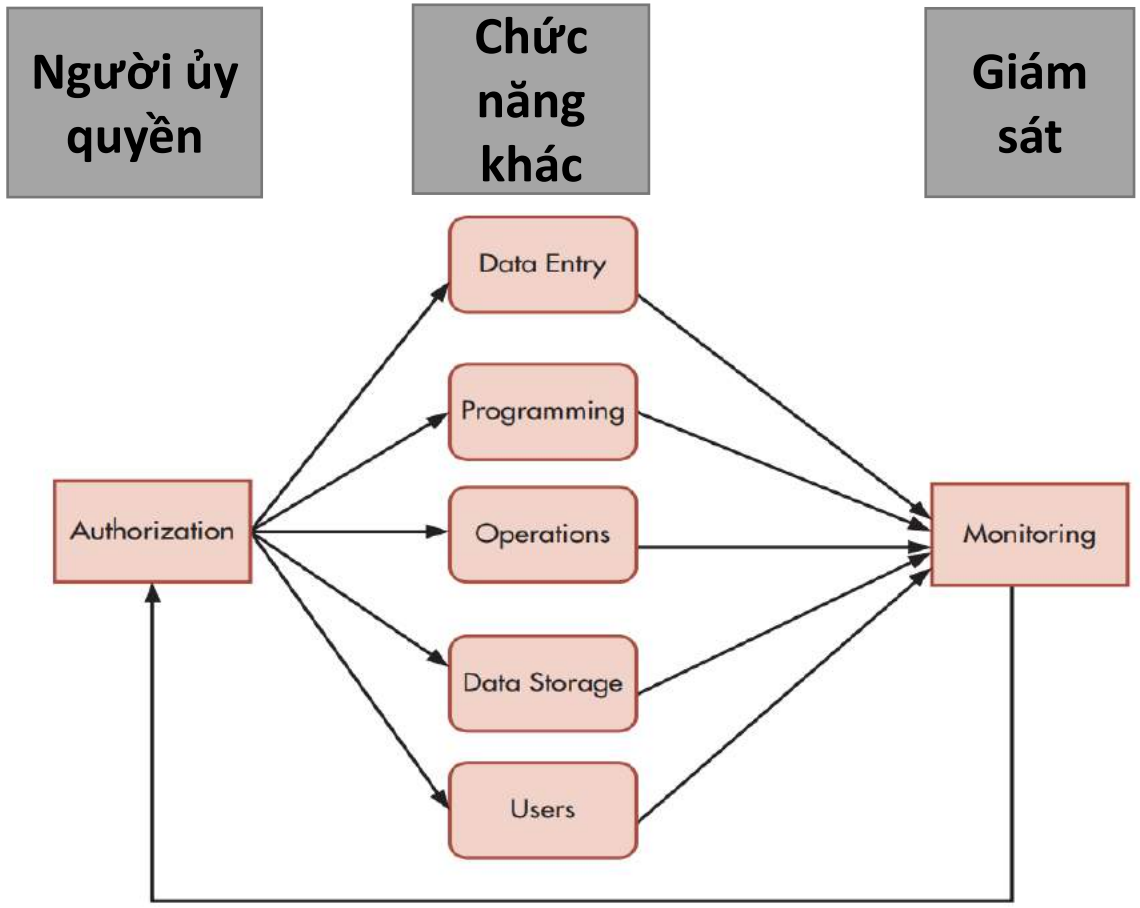
➢ Kiểm soát phân quyền (authoriztion controls)



- Phân chia trách nhiệm kế toán ?
- Phân chia trách nhiệm hệ thống thông tin ?

❖Qui trình : Kiểm soát truy cập người dùng

Phân chia trách nhiệm trong hệ thống máy tính(Segregation of Systems duties)



❖Qui trình : Kiểm soát truy cập người dùng

Phân chia trách nhiệm trong hệ thống máy tính(Segregation of Systems duties)

Chức năng ủy quyền, xét duyệt (Authorization)

- Ủy quyền cho phép nghiệp vụ hoặc hoạt động thực hiện:
- Ủy quyền chung để xử lý các nghiệp vụ
- Ủy quyền cụ thể các nghiệp vụ .
- Phê duyệt các khai báo mối quan hệ kinh doanh mới: Khách hàng mới, nhà cung cấp mới
- Phê duyệt kích hoạt tài khoản người dùng mới
- Phê duyệt việc tạo hoặc sửa đổi các chương trình máy tính
- Phê duyệt chương trình trước khi sử dụng chính thức

❖Qui trình : Kiểm soát truy cập người dùng

Phân chia trách nhiệm trong hệ thống máy tính(Segregation of Systems duties)

Chức năng nhập liệu

❖Nhập liệu nghiệp vụ kinh tế phát sinh

❖Chỉ được nhập sau khi được ủy quyền cho phép

- Nhập liệu mối quan hệ mới (khách hàng, nhà cung cấp, v.v..)
- Nhập liệu tạo người sử dụng mới
- Hủy dữ liệu TK người sử dụng hoặc khách hàng, nhà cung cấp nếu không còn sử dụng

❖Qui trình : Kiểm soát truy cập người dùng

Phân chia trách nhiệm trong hệ thống máy tính(Segregation of Systems duties)

Chức năng lập trình (programming)

- Phân tích
- Lập trình
  - Thiết kế, test chương trình Hệ thống mới
  - Sửa chữa hệ thống hiện hành

Chức năng hoạt động (computer operation)

- Cài đặt phần mềm
- Đảm bảo hoạt động xử lý dữ liệu (nhập, xử lý, tạo thông tin) đúng

❖Qui trình : Kiểm soát truy cập người dùng

Phân chia trách nhiệm trong hệ thống máy tính(Segregation of Systems duties)

Chức năng lưu trữ dữ liệu (Data storage)

- Lưu trữ dữ liệu về mặt vật lý và bảo dưỡng CSDL, tập tin và chương trình.
- Bảo dưỡng các tập tin lưu dự phòng tại nơi lưu trữ (offsite)
- Giữ các thiết bị vật lý có chứa dữ liệu

Chức năng sử dụng (users)

- Ghi nhận nghiệp vụ. Ủy quyền nghiệp vụ để xử lý
- Truy cập dữ liệu để xử lý tạo thông tin

❖Qui trình : Kiểm soát truy cập người dùng

Phân chia trách nhiệm trong hệ thống máy tính(Segregation of Systems duties)

Chức năng quản lý (Management)

- *Quản trị hệ thống* (systems *Administration)*. Người quản trị HT (systems administrators) cần đảm bảo tất cả các thành phần của HT vận hành tốt và hiệu quả
- *Quản trị mạng (network management).* Người quản trị mạng (network manager) đảm bảo mạng nội bộ và các thiết bị kết nối mạng internet vận hành tốt, phù hợp

❖Qui trình : Kiểm soát truy cập người dùng

Phân chia trách nhiệm trong hệ thống máy tính(Segregation of Systems duties)

Chức năng quản lý (Management)

- *Quản trị an toàn (secure management)*. Đảm bảo ANTT cho hệ thống và mạng.
- *Quản lý thay đổi (change management).* Đảm bảo các thay đổi không ảnh hưởng tới tính tin cậy (liability) an toàn (security), bảo mật (confidentiality), toàn vẹn (integrity) và sẵn sàng/khả dụng (availability) của hệ thống.

❖Qui trình : Kiểm soát truy cập người dùng

Phân chia trách nhiệm trong hệ thống máy tính(Segregation of Systems duties)

Chức năng quản lý (Management)

- *Kiểm soát dữ liệu (data control).*
  - Đảm bảo dữ liệu nguồn được xét duyệt đúng
  - Giám sát luân chuyển Dl này trong hệ thống máy tính
  - Đối chiếu đầu vào, đầu ra
  - Xử lý sai sót nhập liệu
  - Phân phối / truyền thông tin

- *Quản trị CSDL (Database administrator): kiểm soát, quản lý CSDL*

❖Qui trình : Kiểm soát truy cập người dùng

➢ Kiểm soát phân quyền (authoriztion controls)

❑ Phân chia trách nhiệm/phân quyền nhóm người sử dụng

- Thực hiện các vùng chức năng: ủy quyền, ghi chép, bảo vệ TS
- Thực hiện truy cập dữ liệu: Ghi chép nghiệp vụ, ủy quyền dữ liệu cho xử lý; sử dụng kết xuất. Các mức độ truy cập theo từng tập tin:
  - Đọc dữ liệu (tập tin nghiệp vụ và tập tin chính)
  - Tạo dữ liệu tập tin chính (create)
  - Nhập dữ liệu nghiệp vụ
  - Cập nhật dữ liệu
  - Hủy dữ liệu

❖Giải pháp IT: Kiểm soát phần mềm độc hại (malware) – ANTIMALWARE CONTROL

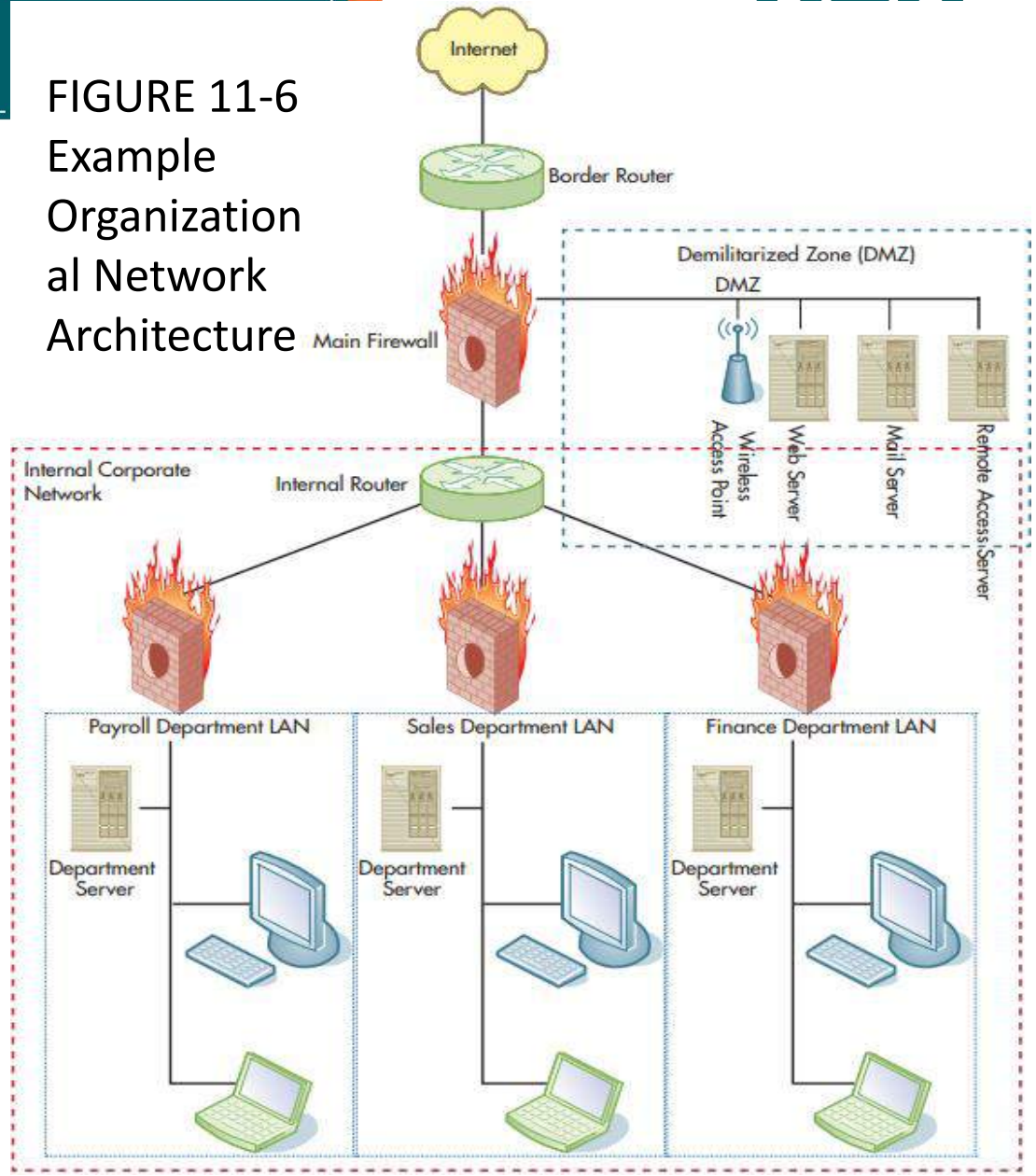
- **Malware:** Viruses, worms, keystroke logging software etc..
- **Các thủ tục**
  - Huấn luyện nhận diện malware
  - Cài đặt công cụ/ phần mềm bảo vệ để chống malware
  - Cập nhật thường xuyên phần mềm/công cụ bảo vệ
  - Kiểm tra thường xuyên phát hiện malware mới
  - Lọc để khóa các thông tin nhận từ các nguồn có nguy cơ độc hại
  - Kiểm soát việc nhân viên tự động cài đặt các phần mềm hay chương trình chưa được duyệt

1.2. Bảo vệ nguồn lực thông tin

❖Giải pháp IT: Kiểm soát truy cập mạng (NETWORK ACCESS CONTROLs)

- Sử dụng hệ thống các thiết bị bảo vệ an toàn và ngăn ngừa xâm nhập: border router; Firewall; demilitarized Zone (DMZ)
- Đảm bảo an toàn kết nối từ xa/ bên ngoài hệ thống qua thiết bị kết nối (modem) và mạng không dây (wireless)
- Kiểm soát truyền tải thông tin trên mạng truyền thông: cắt các mẩu thông tin, nhận và truy cập mẩu thông tin truyền tải;

FIGURE 11-6 Example Organizational Network Architecture



1.2. Bảo vệ nguồn lực thông tin

❖Giải pháp IT: Kiểm soát phần mềm và thiết bị (device and software hardening controls)

- Kiểm soát các thiết bị tại điểm cuối (endpoint) tại vi trí làm việc; Máy chủ , máy in, thiết bị khác
- Quản lý tài khoản người sử dụng
  - Người quản lý hệ thống: có quyền truy cập không giới hạn tới hệ thống.
    - Cài đặt phần mềm
    - Chỉnh sửa các thiết lập cấu hình hệ thống
  - Tài khoản người quản lý HT là mục tiêu của tấn công và cũng là lạm quyền quyền lý -> Giải pháp, (1) tạo 2 tài khoản, 1 TK là quyền quản lý, 1 TK là thông thường với những giới hạn quyền; (1) Thường xuyên đổi password của TK quyền quản lý

1.2. Bảo vệ nguồn lực thông tin

❖Giải pháp IT: Mã hóa dữ liệu (Encryption)

- Mã hóa dùng để bảo vệ các thông tin nhạy cảm khỏi các truy cập bất hợp pháp

❖Phân tích nhật ký truy cập (log analysis)

- Phân tích nhật ký truy cập: là qui trình kiểm tra nhật ký để xác định bằng chứng về các cuộc tấn công có thể xảy ra
- Phân tích những cố gắng đăng nhập nhưng không thành công -> Tìm nguyên nhân
- Phân tích thay đổi trong nhật ký truy cập
- Thực hiện phân tích thường xuyên

❖Hệ thống phát hiện xâm nhập (Istruction Detection Systems)

- IDS là một bộ gồm các cảm biến (sensors) và đơn vị giám sát trung tâm (central mornitoring unit). Nó tạo nhật ký của tất cả lưu lượng mạng đã được phép vượt tường lửa, và phân tích các bản ghi đó để tìm dấu hiệu của cố gắng hoặc thành công xâm nhập
- Một IDS có thể được cài đặt trên một thiết bị cụ thể để giám sát các nỗ lực trái phép nhằm thay đổi cấu hình của thiết bị đó, và cảnh báo khi phát hiện một kiểu lưu lượng truy cập mạng đáng ngờ

❖ Thiết lập đội ứng phó sự cố máy tính (computer incident response team- CIRT)

- CIRT chịu trách nhiệm xử lý các sự cố bảo mật nghiêm trọng.
- Thành phần: Chuyên gia kỹ thuật và ban quản lý cấp cao DN
- Qui trình phản ứng sự cố gồm
  - ✓ Ghi nhận có vấn đề tồn tại.
  - ✓ Ngăn chặn vấn đề.
  - ✓ Phục hồi.
  - ✓ Theo dõi.

❖ VAI TRÒ GIÁM ĐỐC AN TOÀN THÔNG TIN CHIEF INFORMATION SECURITY OFFICER –CISO)

- CISO phải có trách nhiệm đảm bảo rằng các đánh giá về điểm yếu tiềm ẩn (vulnerabilities) và rủi ro được thực hiện thường xuyên và các cuộc kiểm toán an toàn TT được thực hiện định kỳ.
- CISO
  - ✓ làm việc và báo cáo cho CIO;
  - ✓ hợp tác chặt chẽ với người chịu trách nhiệm về an toàn vật lý

❖Thử nghiệm thâm nhập (Penetration test)

Thử nghiệm thâm nhập là một nỗ lực được ủy quyền, được thực hiện bởi nhóm kiểm toán nội bộ hoặc công ty tư vấn bảo mật bên ngoài để đột nhập vào hệ thống thông tin của tổ chức. Các nhóm này cố gắng làm mọi cách có thể để xâm phạm hệ thống của công ty.

1.5. Giám sát và sửa đổi các giải pháp bảo mật

❖Kiểm soát thay đổi và quản lý việc thay đổi

- Là qui trình nhằm đảm bảo rằng các sửa đổi với phần cứng, phần mềm hoặc các qui trình không làm giảm độ tin cậy của hệ thống

- Kiểm soát được thiết kế tốt gồm những đặc tính sau:
  - ***Lập hồ sơ*** tất cả những yêu cầu thay đổi, bản chất, lý do thay đổi, ngày yêu cầu thay đổi, và kết quả của yêu cầu thay đổi
  - ***Phê duyệt*** Tất cả những yêu cầu thay đổi bởi cấp quản lý phù hợp
  - ***Kiểm tra thử*** tất cả những thay đổi trên một hệ thống riêng biệt
  - ***Xây dựng, thực hiện và giám sát*** đầy đủ các hoạt động KS chuyển đổi
  - ***Cập nhật tất cả tài liệu*** để phản ánh những thay đổi mới được triển khai
  - ***Có qui trình đặc biệt*** để xem xét, phê duyệt và tài liệu hóa một cách kịp thời ***cho những thay đổi khẩn cấp***
  - ***Phát triển và lập hồ sơ để tạo điều kiện hoàn nguyên*** (reverting) về cấu hình trước đó nếu việc thay đổi tạo ra những sự cố không mong đợi.
  - ***Giám sát và đánh giá cẩn trọng*** quyền của người dùng trong suốt quá trình thay đổi nhằm đảm bảo duy trì việc phân chia trách nhiệm một cách phù hợp

Mục lục

2.1. Bảo vệ tính bảo mật (confidentiality) tài sản trí tuệ và quyền riêng tư (private)

2.2. Luật và những nguyên tắcđược chấp nhận chung về quyền riêng tư

2.3. Môt số công nghệ bảo mật và quyền riêng tư

❖Mục tiêu:

Bảo vệ các thông tin nhạy cảm khỏi những truy cập và công bố không được ủy quyền.

- Bảo mật thông tin (confidentiality): Bảo vệ tính *bảo mật của tài sản trí tuệ* của một tổ chức
- Bảo vệ quyền riêng tư (privacy) của *thông tin cá nhân* mà nó thu thập từ *khách hàng*, *nhân viên*, *nhà cung cấp* và *bên đối tác* kinh doanh

2.1. Bảo vệ tính bảo mật tài sản trí tuệ và quyền riêng tư

- Tài sản trí tuệ/ sở hữu trí tuệ (Intellectual Property) là những sản phẩm sáng tạo từ con người.

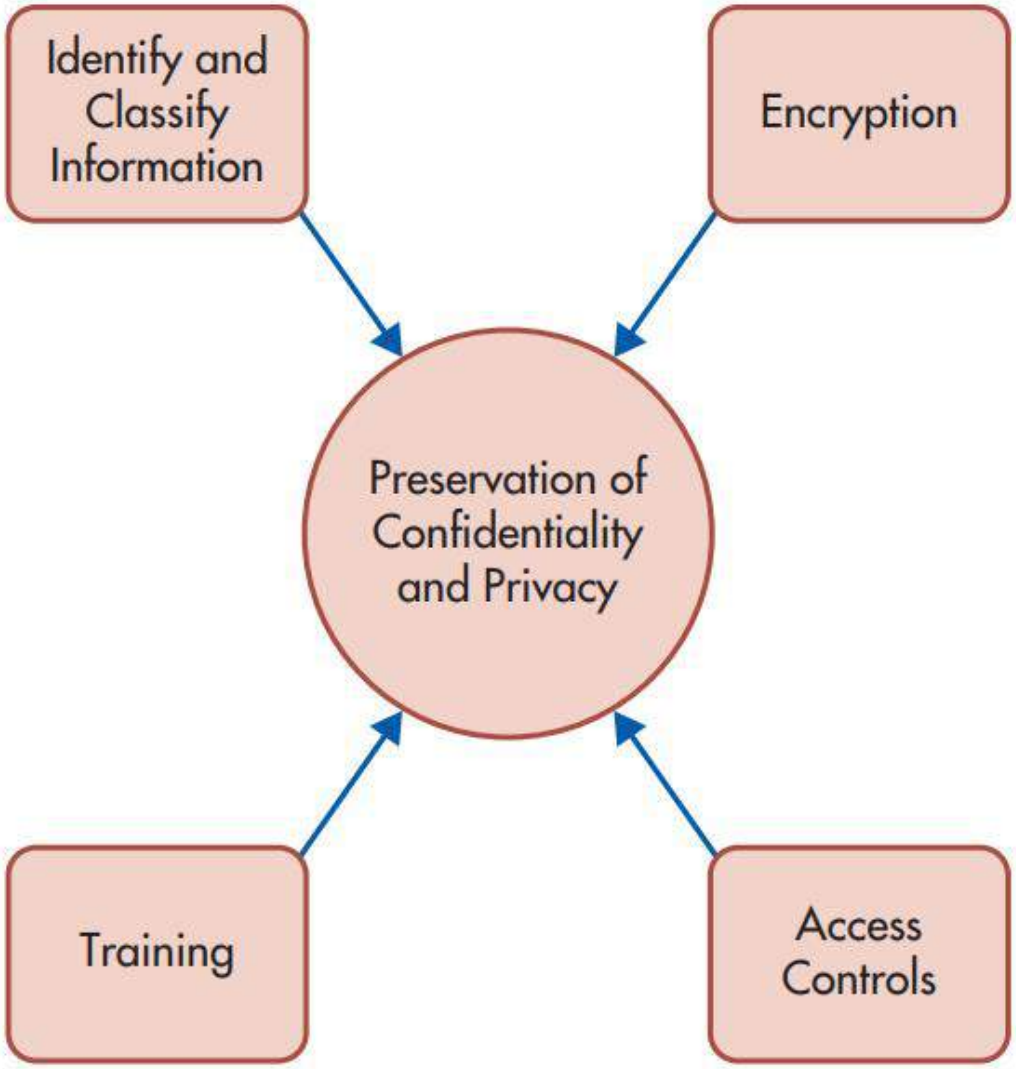
❖ Ở DN, nó thường là:

- ✓ Kế hoạch chiến lược,
- ✓ Bí mật thương mại,
- ✓ Thông tin chi phí
- ✓ Hồ sơ pháp lý
- ✓ Cải tiến quy trình.

Tài sản trí tuệ này thường rất quan trọng đối với lợi thế cạnh tranh và thành công lâu dài của tổ chức

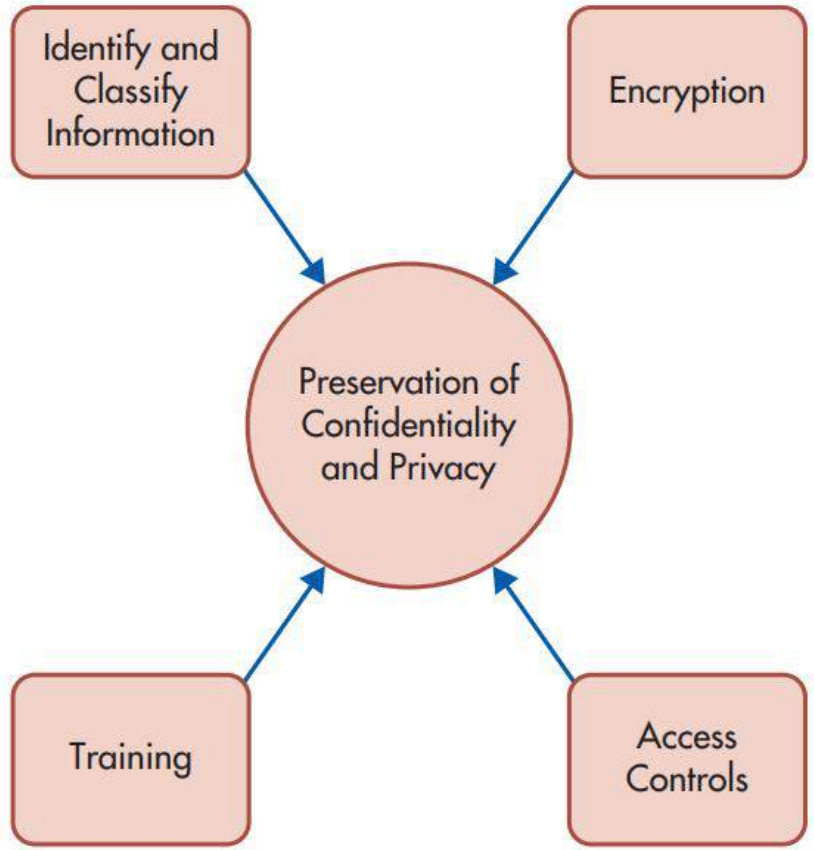
2.1. Bảo vệ tính bảo mật tài sản trí tuệ và quyền riêng tư

FIGURE 12-1 Components of Protecting Confidentiality and Privacy

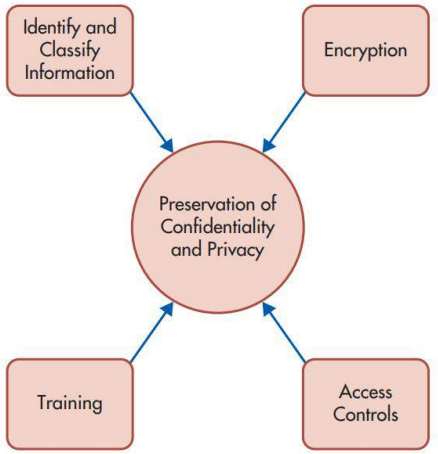


❖Xác định và phân loại thông tin cần được bảo mật

- Là bước đầu tiên trong qui trình bảo vệ tính bảo mật và quyền riêng tư
- Nội dung;
  - ✓ Xác định nơi lưu trữ và người được quyền truy cập
  - ✓ Phân loại thông tin cần bảo vệ theo giá trị của nó với tổ chức

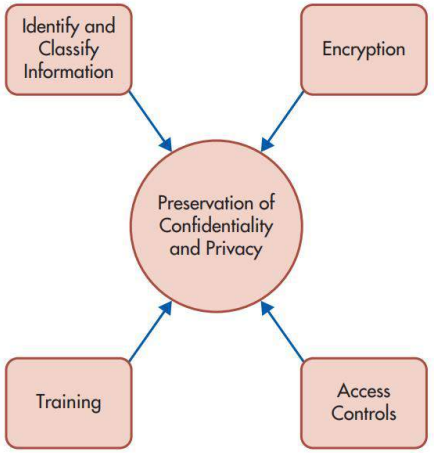


❖ Mã hóa thông tin



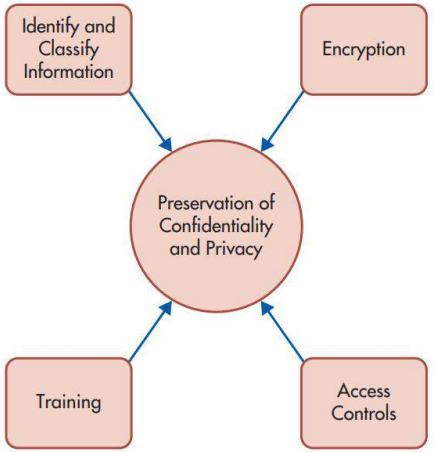
- Mã hóa là qui trình chuyển nội dung thông thường (plaintext) thành nội dung không thể đọc được bằng mắt thường (ciphertext)
- Đoc nội dung mã hóa: cần qui trình giải mã
  - Mã hóa là công cụ quan trong và hữu hiệu để đảm bảo tính bảo mật
    - Đối với thông tin được chuyển giao trên Internet: Mã hóa là cách duy nhất
    - Đối với thông tin được lưu trữ trên web hoặc điện toán đám mây công cộng (public cloud): mã hóa là một phần của việc phòng thủ sâu (defense-in-depth).
  - Mã hóa không phải "thuốc chữa bách bệnh"
    - Những thông tin xử lý đường tắt "process short cut" không được lưu trữ dưới dạng số thì không thể mã hóa
    - Mã hóa cần phải kết hợp với kiểm soát xác thực, và kiểm soát truy cập vật lý

❖ Kiểm soát truy cập



- Kiểm soát xác thực và phân quyền (kiểm soát truy cập của người dùng – kiểm soát an toàn)
- Phần mềm quản trị quyền thông tin (IRM)
- Phần mềm ngăn chặn mất dữ liệu (DLP)
- Chữ ký ảnh điện tử (digital watermark)
- Hạn chế tiếp cận với thiết bị vật lý máy in, máy photo, máy fax, sử dụng thiết bị bảo vệ màn hình cho laptop (screen protection devices)
- Những qui định đối với môi trường ảo hóa (virtualization) và điện toán đám mây (cloud computing)

❖ Huấn luyện nhân viên



- Nhân viên cần biết thông tin nào được phép chia sẻ với bên ngoài, thông tin nào cần được bảo vệ
- Nhân viên cần được hướng dẫn ***cách*** bảo vệ dữ liệu bí mật:
  - Cách sử dụng phần mềm mã hóa
  - Luôn thoát ra khỏi các ứng dụng sau khi sử dụng
  - Sử dụng màn hình được bảo vệ bằng mật khẩu (password-protected screen)
  - Biết cách mã hóa các báo cáo thông tin quan trọng
  - Biết cách sử dụng đúng email, tin nhắn chat, blogs, cách xóa thông tin

2.2. Luật và những nguyên tắcđược chấp nhận chung về quyền riêng tư

- **"Nguyên tắc Quyền riêng tư được Chấp nhận Chung- Generally Accepted Privacy Principles- GAPP"**: AICPA & CICA cùng phát triển một khuôn mẫu

❖**GAPP gồm 10 thực hành tốt nhất được công nhận quốc tế để bảo vệ quyền riêng tư**

- **1. Management Quản lý .**
  - ✓Các tổ chức cần thiết lập một bộ quy trình và chính sách để bảo vệ quyền riêng tư của thông tin cá nhân
  - ✓Chỉ định vị trí nhân viên chịu trách nhiệm bảo mật dữ liệu "a Data Privacy Officer."

❖GAPP gồm 10 thực hành tốt nhất được công nhận quốc tế để bảo vệ quyền riêng tư

- **2. Notice. Thông báo.** Cần cung cấp thông báo về các chính sách và thực hành trước khi thu thập thông tin cá nhân:
  - ✓ Thông tin nào đang được thu thập
  - ✓ Lý do thu thập thông tin
  - ✓ Cách thông tin sẽ được sử dụng.
- **3. Choice and consent. Lựa chọn và đồng ý**

Các tổ chức nên giải thích các lựa chọn có sẵn cho các cá nhân và nhận được sự đồng ý của họ trước khi thu thập và sử dụng thông tin cá nhân của họ

❖GAPP gồm 10 thực hành tốt nhất được công nhận quốc tế để bảo vệ quyền riêng tư

- **4. Collection. Thu thập.**

Một tổ chức chỉ nên thu thập thông tin cần thiết để thực hiện các mục đích được nêu trong chính sách quyền riêng tư.

- **5. Use, retention, and disposal. Sử dụng, lưu giữ và loại bỏ.**

✓ Các tổ chức chỉ nên sử dụng thông tin cá nhân của khách hàng theo cách được mô tả trong chính sách và duy trì thông tin chỉ khi nó cần thiết để thực hiện mục đích kinh doanh hợp pháp.

✓ Khi không còn cần thì cần loại bỏ đúng nguyên tắc an toàn

✓ Cần chỉ định người chịu trách nhiệm xóa và loại bỏ thông tin

❖GAPP gồm 10 thực hành tốt nhất được công nhận quốc tế để bảo vệ quyền riêng tư

- **6. Access.Truy cập.** Nên cung cấp cho các cá nhân khả năng truy cập, xem xét và sửa thông tin cá nhân được lưu trữ về họ.
- **7. Disclosure to third parties.Tiết lộ cho bên thứ ba.**
  - ✓ Chỉ tiết lộ thông tin cá nhân của khách hàng cho bên thứ ba trong các tình huống và cách thức được mô tả trong chính sách quyền riêng tư của đơn vị
  - ✓ Và, chỉ khi bên thứ ba cung cấp mức độ bảo vệ quyền riêng tư giống như đơn vị
- → Khi sử dụng điện toán đám mây vì việc lưu trữ thông tin cá nhân của khách hàng trên đám mây có thể bị truy cập bởi nhân viên của nhà cung cấp đám mây -> thông tin phải luôn được mã hóa.

❖GAPP gồm 10 thực hành tốt nhất được công nhận quốc tế để bảo vệ quyền riêng tư

8. Security. Bảo mật.

- ✓ Sử dụng các kiểm soát phòng ngừa, phát hiện và sửa chữa an toàn thông tin để hạn chế quyền truy cập thông tin cá nhân
- ✓ Huấn luyện, đào tạo nhân viên về hành vi vi phạm quyền riệng tư và các thủ tục cần thiết để tránh vi phạm quyền riêng tư

❖GAPP gồm 10 thực hành tốt nhất được công nhận quốc tế để bảo vệ quyền riêng tư

9. Quality. Chất lượng. Nên duy trì tính toàn vẹn của thông tin cá nhân của khách hàng và áp dụng các quy trình để đảm bảo thông tin đó chính xác một cách hợp lý (vd, cho phép khách hàng xem lại thông tin cá nhân được tổ chức lưu trữ)

10. Monitoring and enforcement. Giám sát và thực thi.

- ✓ Phải xác minh định kỳ việc tuân thủ các chính sách quyền riêng tư đã nêu.
- ✓ Nên thiết lập các thủ tục để trả lời các khiếu nại của khách hàng, bao gồm cả việc sử dụng quy trình giải quyết tranh chấp của bên thứ ba.

❖TRỘM CẮP DANH TÍNH (IDENTITY THEFT)

Trộm cắp danh tính là việc sử dụng trái phép thông tin cá nhân của ai đó vì lợi ích của thủ phạm:

- ✓ Tài chính: sử dụng danh tính ăn cắp để mở thẻ tín dụng, hoặc đi vay hoặc đánh cắp tài khoản ngân của nạn nhân; Nghĩa vụ nộp và hoàn thuế của nạn nhân
- ✓ Sử dụng dịch vụ y tế:

Các tổ chức cần có trách nhiệm

- ✓ Nghĩa vụ về pháp lý liên quan bảo mật quyền riêng tư cá nhân
- ✓ Nghĩa vụ về về đạo đức và trách nhiệm liên quan bảo mật quyền riêng tư cá nhân

❖TRỘM CẮP DANH TÍNH (IDENTITY THEFT)

Bản thân cá nhân cần tự bảo vệ (focus 12-1)

1. Credit freeze. Yêu cầu đóng băng các báo cáo tín dụng tại các đại lý dịch vụ khai báo tài chính, tín dụng khách hàng
2. Cắt nhỏ tất cả các tài liệu có chứa thông tin cá nhân trước khi loại bỏ hay vứt rác
3. Lưu trữ an toàn các tài liệu chứa thông tin cá nhân quan trọng và thông tin tài chính (ví dụ: tờ khai thuế và báo cáo tài chính). Nên Mã hóa dữ liệu lưu trữ
4. Mã hóa thông tin (số an sinh xã hội, số hộ chiếu, v.v.) khi gửi e-mail.
5. Cảnh giác với các email, điện thoại, tin nhắn yêu cầu xác minh thông tin liên quan thẻ tín dụng
6. Cẩn thận khi mang theo người thẻ an sinh xã hội (social security card)

❖TRỘM CẮP DANH TÍNH (IDENTITY THEFT)

Bản thân cá nhân cần tự bảo vệ (focus 12-1)

7. Từ chối các yêu cầu cung cấp số an sinh xã hội của cá nhân cho các doanh nghiệp yêu cầu nó, vì hiếm khi cần thiết cho hầu hết các giao dịch.
8. Hạn chế các thông tin cá nhân in trước trên SEC; Chỉ in tên viết tắt và họ của bạn trên SEC, thay vì tên đầy đủ của bạn. Điều này ngăn kẻ trộm biết cách bạn ký tên.
9. Không đặt SEC hoặc thông tin cá nhân vào thùng/hộp thư để bên ngoài.
10. Hủy, xóa (bằng phần mềm đặc biệt) các thông tin trên các thiết bị điện tử trước khi thanh lý, vứt bỏ
11. Thường xuyên theo dõi các báo cáo tín dụng của bạn.
12. Thông báo cảnh sát hoặc ngân hàng ngay khi bị đánh cắp ví, thẻ tín dụng. Hủy ngay các thẻ tín dụng nếu bị đánh cắp hay thất lạc
13. Phô tô các giấy tờ cá nhân và cất giữ ở vị trí an toàn để có căn cứ báo và cấp lại

❖CÁC KỸ THUẬT KHÁC

- Mã hóa (encryption)
- Mạng riêng ảo (virtual private network -VPN)
- Hashing
- Chữ ký số (digital signature)

UEH UNIVERSITY

Mục lục

3.1. Kiểm soát đầu vào (input controls)

3.2. Kiểm soát xử lý (processing controls)

3.3. Kiểm soát thông tin đầu ra (output controls)

Phần 3- Kiểm soát tính toàn vẹn

Mục đích:

Kiểm soát toàn vẹn nhằm tạo ra thông tin chính xác, đầy đủ, kịp thời và hợp lệ (p.423).

Process Stage	Threats/Risks	Controls
Input	Data that is: • Invalid • Unauthorized • Incomplete • Inaccurate	Forms design, cancellation and storage of documents, authorization and segregation of duties controls, visual scanning, data entry controls
Processing	Errors in output and stored data	Data matching, file labels, batch totals, cross-footing and zero-balance tests, write-protection mechanisms, database processing integrity controls
Output	• Use of inaccurate or incomplete reports • Unauthorized disclosure of sensitive information • Loss, alteration, or disclosure of information in transit	Reviews and reconciliations, encryption and access controls, parity checks, message acknowledgment techniques, blockchain

3.1. Kiểm soát đầu vào

❖ Kiểm soát nguồn dữ liệu

Mục tiêu kiểm soát

- Nghiệp vụ được xét duyệt
- Nghiệp vụ có thực
- Nghiệp vụ được thu thập đầy đủ
- Dữ liệu nghiệp vụ chính xác
- Đúng kỳ thời gian

Thủ tục kiểm soát

- Thiết kế mẫu chứng từ phù hợp. Đánh số trước cho các chứng từ
- Kiểm tra để đảm bảo dữ liệu đáp ứng mục tiêu kiểm soát
- Tăng cường sử dụng DL trực tiếp từ nguồn DL
- Sử dụng chứng từ luân chuyển
- Sử dụng thiết bị thu thập DL tự động
- Đánh dấu chứng từ đã sử dụng

3.1. Kiểm soát đầu vào

❖ Kiểm soát quá trình nhập liệu

Mục tiêu kiểm soát

- Nhập chính xác DL đã thu thập
- Đầy đủ DL đã thu thập
- Đảm bảo tính toàn vẹn của DL nhập
- Kịp thời
- Hiệu quả

Thủ tục kiểm soát

- Kiểm tra kiểu dữ liệu (field check)
- Kiểm tra dấu (sign check)
- Kiểm tra giới hạn (limit check)
- Kiểm tra giới hạn theo dãy (range check)
- Kiểm tra dung lượng vùng nhập liệu (size check)
- Kiểm tra tính đầy đủ (completeness check/test)
- Kiểm tra tính hợp lệ (validity check)
- Kiểm tra tính hợp lý (reasonableness test)
- Số kiểm tra (check digit) và xác nhận số kiểm tra (check digit verification)

3.1. Kiểm soát đầu vào

❖ Kiểm soát quá trình nhập liệu

VÍ DỤ BẢNG KÊ BÁN HÀNG

SỐ HĐ	NGÀY HĐ	NỘI DUNG	MÃ KH	TÊN KH	MÃ HH	TÊN HH	SL	ĐƠN GIÁ	TIỀN
21	02-02-18		1		A		100	1	100
21	02-02-18		1		B		100	5	450
22	01-02-18		2		B		150	5	700
22	01-02-18		2		C		200	3	600
23	14-02-18		1		A		300	3	900
18	28-01-17		2		C		200	3	600
25	30-02-18		6		D		100	10	1,000

Thông tin bổ sung

- Mặt hàng A tồn đầu ngày 01/02: 80 số lượng, trong ngày 01và 02 không nhập hàng
- Mặt hàng D chưa hề có trong danh mục hàng cũng như trong kho

Yêu cầu

- Nhận diện các sai sót ở bảng kê bán hàng
- Thiết lập các thủ tục kiểm soát ngăn ngừa các sai sót trên

❖ Kiểm soát quá trình nhập liệu

Kiểm soát Nhập liệu trực tuyến (online) (bổ sung thêm)

- Chỉ dẫn (prompting). Hệ thống yêu cầu mỗi vùng nhập liệu cần có xác nhận chấp nhận để đảm bảo tất cả các vùng dữ liệu cần thiết được nhập vào hệ thống
- Kiểm tra vòng lặp kín (kiểm tra dựa vào thông tin liên quan) (closed–loop verification). Kiểm tra tính chính xác của dữ liệu nhập vào bằng cách lấy lại và hiển thị các thông tin liên quan khác.
- 1 nhật ký nghiệp vụ được tạo ra để làm căn cứ khôi phục/tái tạp lại tập tin online đã bị hư

3.1. Kiểm soát đầu vào

❖ Kiểm soát quá trình nhập liệu

Kiểm soát Nhập liệu theo lô

- Kiểm tra theo trình tự (sequence check). Trình tự của lô có đúng như trình tự trên tập tin chính
- Tạo 1 nhật ký các dữ liệu sai sót, không được xử lý
- Tổng lô (batch total)
  - Tổng tài chính (financial total)
  - Tổng Hash (hash total)
  - Đếm mẫu tin (record count)

	Ngày	Số HĐ	Số tiền	Mã Khách hàng
3 mẩu tin	3	1	1.000.000	B
	5	2	300.000	A
	6	3	2.000.000	C
	14	6	3.300.000	

Tổng Hash

Tổng tài chính

3.1. Kiểm soát đầu vào

❖ Kiểm soát xử lý dữ liệu

Mục tiêu: đảm bảo các dữ liệu được cập nhật đúng

Thủ tục kiểm soát

- Kiểm tra sự phù hợp dữ liệu (data matching)
- Kiểm tra nhãn và thuộc tính tập tin dữ liệu (flie labels)
- Kiểm tra tổng số lô sau khi xử lý (batch totals)
- Kiểm tra chéo (cross-footing test) và kiểm tra số dư bằng 0 (zero-balance test)
- Cơ chế chống ghi tập tin (write-protection mechanism)
- Kiểm soát cập nhật đồng thời (concurrent update control) trong trường hợp có nhiều hơn 1 người dùng cùng truy cập đến dữ liệu

❖ Kiểm soát kết quả xử lý

Mục tiêu: Đảm bảo thông tin cung cấp hữu ích, tin cậy (liability)

Thủ tục kiểm soát

- Người dùng kiểm tra, đánh giá thông tin đầu ra
- Quy định các thủ tục và quy trình đối chiếu dữ liệu, thông tin
- Đối chiếu dữ liệu ngoài hệ thống
- Kiểm soát truyền tải dữ liệu

UEH UNIVERSITY

Mục lục

4.1. Giảm thiểu rủi ro thời gian ngưng trệ của hệ thống (system downtime)

4.2. Phục hồi và tiếp tục hoạt động thông thường (recovery & resumption of normal operations)

Phần 4- Kiểm soát tính khả dụng/ sẵn sàng (Availability)

Mục đích:

- Đảm bảo hệ thống và thông tin sẵn sàng khi sử dụng

Objective	Key Controls
1. To minimize risk of system downtime	• Preventive maintenance • Fault tolerance • Data center location and design • Training • Patch management and antivirus software
2. Quick and complete recovery and resumption of normal operations	• Backup procedures • Disaster recovery plan (DRP) • Business continuity plan (BCP)

4.1. Giảm thiểu rủi ro thời gian ngưng trệ của hệ thống (system downtime)

Hoạt động kiểm soát

- Tăng khả năng chịu đựng sự ngưng trệ: Thiết lập các hệ thống/thành phần thiết bị dự phòng trong trường hợp hệ thống ngưng trệ *(redundant arrays of independent drives (RAID)*
- Các biện pháp an toàn tài sản từ các hiểm họa tự nhiên
- Kiểm soát hỏa hoạn
- Kiểm soát hệ thống thiết bị máy tính,
- Kiểm soát nguồn điện
- Dùng hệ thống UPS (uninterruptible power supply)
- Kiểm soát truy cập vật lý
- Huấn luyện đào tạo, cung cấp hồ sơ hướng dẫn xử lý khi hệ thống ngưng trệ
- Kiểm soát phần mềm độc hại: cài đặt sử dụng hệ thống

Hoạt động kiểm soát

- Thủ tục lưu dự phòng dữ liệu (backup)
- Thiết lập kế hoạch:
  - Kế hoạch phục hồi do thảm họa (disaster recovery plan –DRP)
  - Kế hoạch hoạt động kinh doanh liên tục (business continuity plan- BCP)

UEH UNIVERSITY

THỦ TỤC LƯU DỰ PHÒNG DỮ LIỆU

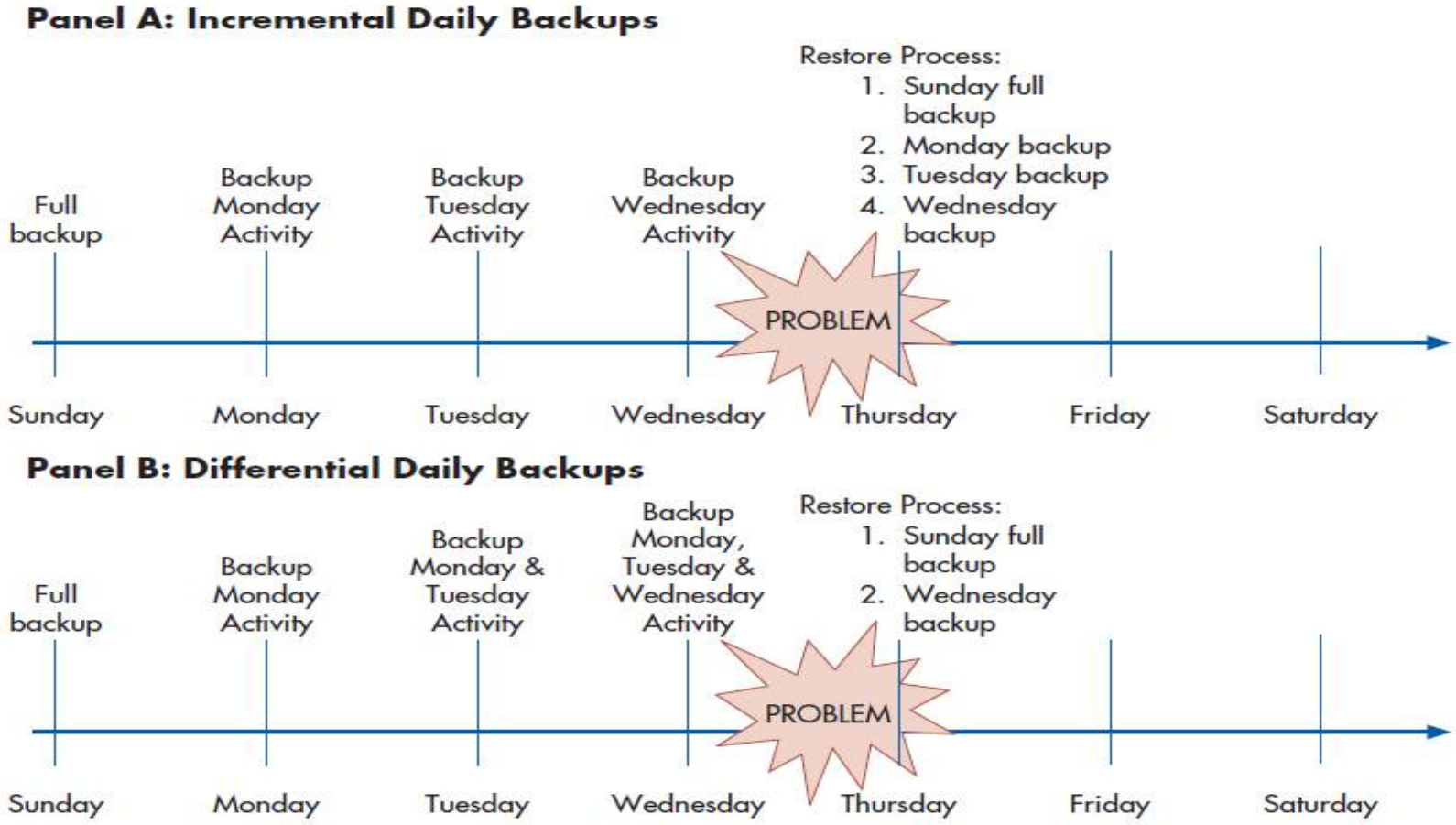
Lưu dự phòng là một bản sao (copy) của hoặc
- cơ sở dữ liệu
- tập tin
- chương trình

➢ **Các thủ tục Lưu dự phòng (backup)**

- Lưu dự phòng toàn bộ: Full backup (toàn bộ CSDL); Cách lưu này tốn thời gian, nên thường định kỳ hàng tuần
- Lưu dự phòng từng phần/hàng ngày (Daily partial backup) Có 2 cách:
  - ✓ Incremental Daily Backup- Sao lưu Chuỗi. Chỉ lưu những dữ liệu thay đổi trong từng ngày kể từ lần lưu cuối cùng trước đó
  - ✓ Differential Daily Backup- Lưu toàn bộ dữ liệu thay đổi lũy kế tới ngày lưu dự phòng

THỦ TỤC LƯU DỰ PHÒNG DỮ LIỆU

Lưu dự phòng là một bản sao (copy) của hoặc
- cơ sở dữ liệu
- tập tin
- chương trình



THỦ TỤC LƯU DỰ PHÒNG DỮ LIỆU

Lưu dự phòng là một bản sao (copy) của hoặc
- Cơ sở dữ liệu
- Tập tin
- Chương trình

➢ **Các thủ tục Lưu dự phòng (tiếp)**

- Nên có nhiều bản sao lưu dự phòng:
  - ✓ 1 để ở ngay tại vị trí hoạt động
  - ✓ 1 để bên ngoài vị trí hoạt động
- Sao lưu dự phòng cần được kiểm soát an toàn:
  - ✓ Mã hóa các thông tin quan trọng, nhạy cảm trong quá trình lưu và chuyển giao (vật lý hoặc điện tử)
  - ✓ Kiểm soát truy cập tập tin lưu dự phòng
  - ✓ Thường xuyên kiểm tra bản sao lưu (VD định kỳ khôi phục lại bản sao lưu để đảm bảo qui trình sao lưu chính xác và sẵn sàng đọc được)
  - ✓ Lưu dự phòng thường được lưu trữ trong thời hạn ngắn

THỦ TỤC LƯU DỰ PHÒNG DỮ LIỆU

Lưu dự phòng là một bản sao (copy) của hoặc
- Cơ sở dữ liệu
- Tập tin
- Chương trình

➢ **Các thủ tục Lưu dự phòng (tiếp)**

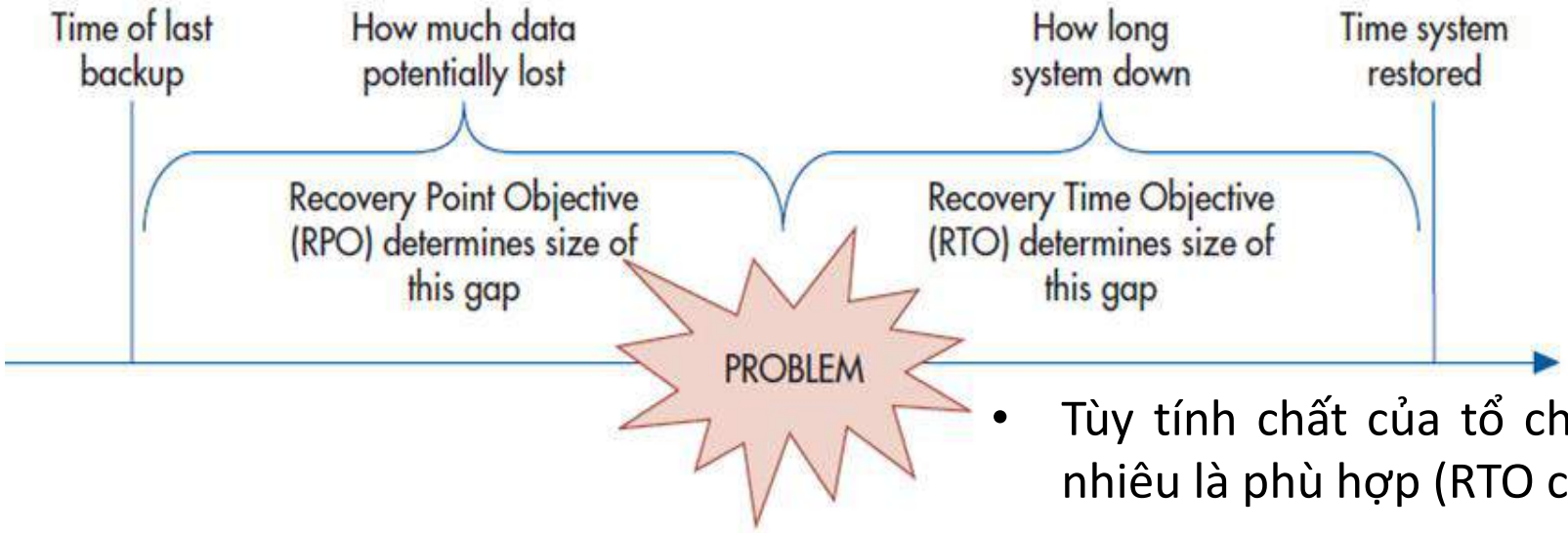
- **Tập tin lưu dài hạn (Archive file).** Là một bản sao của một cơ sở dữ liệu, tập tin chính hoặc phần mềm. Nó được lưu giữ vô thời hạn như một hồ sơ lịch sử, và thường dùng để đáp ứng pháp lý và các yêu cầu quy định.
- Có thể sử dụng cả đĩa từ và băng từ để lưu trữ dự phòng và lưu dài hạn

LẬP KẾ HOẠCH PHỤC HỒI SAU THẢM HỌA VÀ HOẠT ĐỘNG KINH DOANH LIÊN TỤC

- Lập kế hoạch phục hồi sau thảm họa và hoạt động kinh doanh liên tục tạo ra các bản kế hoạch:
  - Kế hoạch phục hồi sau thảm họa (disaster recovery plan –DRP)
  - Kế hoạch hoạt động kinh doanh liên tục (business continuity plan- BCP)
    - Để thiết lập DRP & BCP, cần trả lời 2 câu hỏi
      - Bao nhiêu dữ liệu có thể tái tạo lại từ chứng từ gốc (nếu có) hoặc bao nhiêu dữ liệu bị mất/hư hỏng (nếu không có chứng từ gốc)
      - Doanh nghiệp có thể tồn tại được bao lâu nếu không có hệ thống thông tin hiện hành

LẬP KẾ HOẠCH PHỤC HỒI SAU THẢM HỌA VÀ HOẠT ĐỘNG KINH DOANH LIÊN TỤC

*RPO (MỐC PHỤC HỒI DỮ LIỆU) VÀ RTO (MỐC THỜI GIAN PHỤC HỒI)



- Tùy tính chất của tổ chức để xác định RPO và RTO bao nhiêu là phù hợp (RTO có thể đo lường theo giờ hay ngày)
- RPO tỷ lệ nghịch với tần suất sao lưu dự phòng (backup)
- RTO càng dài; RPO càng lớn thì mức độ đầu tư cho DRP và BCP càng ít hơn -> chi phí sẽ thấp hơn so RTO & RPO thấp

LẬP KẾ HOẠCH PHỤC HỒI SAU THẢM HỌA

- Kế hoạch phục hồi sau thảm họa (DRP): liệt kê các thủ tục để khôi phục các chức năng hoạt động của DN trong trường hợp trung tâm dữ liệu bị phá hủy bởi tự nhiên hoặc khủng bố
- Lập hồ sơ DRP
- Kiểm tra/test DRP định kỳ (thường hàng năm)

LẬP KẾ HOẠCH PHỤC HỒI SAU THẢM HỌA (tiếp tục)

- Có 3 lựa chọn cho thay thế/dự phòng cơ sở hạ tầng CNTT (gồm phần mềm, mạng truyền thông, Router, dữ liệu v.v…
  - Cold site (địa điểm chờ)
  - Hot site (địa điểm ngay lập tức)
  - Real-time mirroring. Duy trì hai trung tâm dữ liệu riêng biệt với bản sao hoàn chỉnh của 1 cơ sở dữ liệu và cập nhật cả hai bản sao CSDL theo thời gian thực khi mỗi giao dịch xảy ra.

Lựa chọn cách nào tùy thuộc
- Khả năng chi phí
- Phản ánh quyết định về mức RPO & RTO

LẬP KẾ HOẠCH HOẠT ĐỘNG KINH DOANH LIÊN TỤC

- Kế hoạch hoạt động kinh doanh liên tục BCP xác định cách thức hoạt động lại của hệ thống IT và qui trình kinh doanh
  - Xác định vị trí dự phòng
  - Thuê chỗ thay thế tạm thời
  - V.v...
- Lập hồ sơ BCP
- Xem xét lại và kiểm tra định kỳ BCP (thường là hàng năm)

ẢO HÓA (VIRTUALIZATION) VÀ ĐIỆN TOÁN ĐÁM MÂY (CLOUD COMPUTING)

- Ảo hóa và điện toán đám mây giúp gia tăng tính hữu hiệu và hiệu quả của các hoạt động khôi phục thảm họa và tiếp tục lại hoạt động kinh doanh.

Tổng kết